

Privacy by design (PbD) is an approach to systems engineering initially developed by Ann Cavoukian and formalized in a joint report on privacy-enhancing technologies by a joint team of the Information and Privacy Commissioner of Ontario (Canada), the Dutch Data Protection Authority, and the Netherlands Organisation for Applied Scientific Research in 1995. The privacy by design framework was published in 2009 and adopted by the International Assembly of Privacy Commissioners and Data Protection Authorities in 2010. Privacy by design calls for privacy to be taken into account throughout the whole engineering process. The concept is an example of value sensitive design, i.e. taking human values into account in a well-defined manner throughout the design process.

Cavoukian's approach to privacy has been criticized as being vague, challenging to enforce its adoption, difficult to apply to certain disciplines, challenging to scale up to networked infrastructures, as well as prioritizing corporate interests over consumers' interests, and placing insufficient emphasis on minimizing data collection. Recent developments in computer science and data engineering, such as support for encoding privacy in data and the availability and quality of Privacy-Enhancing Technologies (PET's) partly offset those critiques and help to make the principles feasible in real-world settings.

The European GDPR regulation incorporates privacy by design.

History and background

The privacy by design framework was developed by Ann Cavoukian, Information and Privacy Commissioner of Ontario, following her joint work with the Dutch Data Protection Authority and the Netherlands Organisation for Applied Scientific Research in 1995.

In 2009, the Information and Privacy Commissioner of Ontario co-hosted an event, Privacy by Design: The Definitive Workshop, with the Israeli Law, Information and Technology Authority at the 31st International Conference of Data Protection and Privacy Commissioners (2009).

In 2010 the framework achieved international acceptance when the International Assembly of

Privacy Commissioners and Data Protection Authorities unanimously passed a resolution on privacy by design recognising it as an international standard at their annual conference. Among other commitments, the commissioners resolved to promote privacy by design as widely as possible and foster the incorporation of the principle into policy and legislation.

Foundational principles

Privacy by design is based on seven "foundational principles":

Proactive not reactive; preventive not remedial

Privacy as the default setting

Privacy embedded into design

Full functionality – positive-sum, not zero-sum

End-to-end security – full lifecycle protection

Visibility and transparency – keep it open

Respect for user privacy – keep it user-centric

The principles have been cited in over five hundred articles referring to the Privacy by Design in Law, Policy and Practice white paper by Ann Cavoukian.

Principles in detail

Proactive not reactive; preventive not remedial

The privacy by design approach is characterized by proactive rather than reactive measures. It anticipates and prevents privacy invasive events before they happen. Privacy by design does not wait for privacy risks to materialize, nor does it offer remedies for resolving privacy infractions once they have occurred — it aims to prevent them from occurring. In short, privacy by design comes before-the-fact, not after.

Privacy as the default

Privacy by design seeks to deliver the maximum degree of privacy by ensuring that personal data are automatically protected in any given IT system or business practice. If an individual does nothing, their privacy still remains intact. No action is required on the part of the individual to protect their privacy — it is built into the system, by default.

PbD practices

Purpose Specification - The data subjects must be clearly communicated to at or before any data collection, retention, or usage occurs, and the purpose(s) must be limited and relevant to the stated needs.

Collection Limitation - Collection of data must be fair, lawful, and limited to the stated purpose.

Data minimization - Collection of data should be minimized as much as possible, and technologies should default to have users be non-identifiable and non-observable or minimized if absolutely necessary.

Use, Retention, and Disclosure - Use, retention, and disclosure of data must be limited and only for what has been consented to, with exceptions by law. Information should only be retained for the stated amount time needed and then securely erased.

Privacy embedded into design

Privacy by design is embedded into the design and architecture of IT systems as well as business practices. It is not bolted on as an add-on, after the fact. The result is that privacy becomes an essential component of the core functionality being delivered. Privacy is integral to the system without diminishing functionality.

Full functionality – positive-sum, not zero-sum

Privacy by design seeks to accommodate all legitimate interests and objectives in a positive-sum “win-win” manner, not through a dated, zero-sum approach, where unnecessary trade-offs are made. Privacy by design avoids the pretense of false dichotomies, such as privacy versus security, demonstrating that it is possible to have both.

End-to-end security – full lifecycle protection

Privacy by design, having been embedded into the system prior to the first element of information being collected, extends securely throughout the entire lifecycle of the data involved — strong security measures are essential to privacy, from start to finish. This ensures that all data are securely retained, and then securely destroyed at the end of the process, in a timely fashion. Thus, privacy by design ensures cradle-to-grave, secure lifecycle management of information, end-to-end.

Visibility and transparency – keep it open

Privacy by design seeks to assure all stakeholders that whatever business practice or technology involved is in fact operating according to the stated promises and objectives, subject to independent verification. The component parts and operations remain visible and transparent, to users and providers alike. Remember to trust but verify.

Respect for user privacy – keep it user-centric

Above all, privacy by design requires architects and operators to keep the interests of the individual uppermost by offering such measures as strong privacy defaults, appropriate notice, and empowering user-friendly options. Keep it user-centric.

Design and standards

The International Organization for Standardization (ISO) approved the Committee on

Consumer Policy (COPOLCO) proposal for a new ISO standard: Consumer Protection: Privacy by Design for Consumer Goods and Services (ISO/PC317). The standard will aim to specify the design process to provide consumer goods and services that meet consumers' domestic processing privacy needs as well as the personal privacy requirements of data protection. The standard has the UK as secretariat with thirteen participating members and twenty observing members.

The Standards Council of Canada (SCC) is one of the participating members and has established a mirror Canadian committee to ISO/PC317.

The OASIS Privacy by Design Documentation for Software Engineers (PbD-SE) Technical Committee provides a specification to operationalize privacy by design in the context of software engineering. Privacy by design, like security by design, is a normal part of the software development process and a risk reduction strategy for software engineers. The PbD-SE specification translates the PbD principles to conformance requirements within software engineering tasks and helps software development teams to produce artifacts as evidence of PbD principle adherence. Following the specification facilitates the documentation of privacy requirements from software conception to retirement, thereby providing a plan around adherence to privacy by design principles, and other guidance to privacy best practices, such as NIST's 800-53 Appendix J (NIST SP 800-53) and the Fair Information Practice Principles (FIPPs) (PMRM-1.0).

Relationship to privacy-enhancing technologies

Privacy by design originated from privacy-enhancing technologies (PETs) in a joint 1995 report by Ann Cavoukian and John Borking. In 2007 the European Commission provided a memo on PETs. In 2008 the British Information Commissioner's Office commissioned a report titled Privacy by Design – An Overview of Privacy Enhancing Technologies.

There are many facets to privacy by design. There is the technical side like software and

systems engineering, administrative elements (e.g. legal, policy, procedural), other organizational controls, and operating contexts. Privacy by design evolved from early efforts to express fair information practice principles directly into the design and operation of information and communications technologies. In his publication *Privacy by Design: Delivering the Promises* Peter Hustinx acknowledges the key role played by Ann Cavoukian and John Borking, then Deputy Privacy Commissioners, in the joint 1995 publication *Privacy-Enhancing Technologies: The Path to Anonymity*. This 1995 report focussed on exploring technologies that permit transactions to be conducted anonymously.

Privacy-enhancing technologies allow online users to protect the privacy of their Personally Identifiable Information (PII) provided to and handled by services or applications. Privacy by design evolved to consider the broader systems and processes in which PETs were embedded and operated. The U.S. Center for Democracy & Technology (CDT) in *The Role of Privacy by Design in Protecting Consumer Privacy* distinguishes PET from privacy by design noting that “PETs are most useful for users who already understand online privacy risks. They are essential user empowerment tools, but they form only a single piece of a broader framework that should be considered when discussing how technology can be used in the service of protecting privacy.”

Global usage

Germany released a statute (§ 3 Sec. 4 Teledienststedatenschutzgesetz [Teleservices Data Protection Act]) in July 1997. The new EU General Data Protection Regulation (GDPR) includes ‘data protection by design’ and ‘data protection by default’, the second foundational principle of privacy by design. Canada's Privacy Commissioner included privacy by design in its report on *Privacy, Trust and Innovation – Building Canada's Digital Advantage*. In 2012, U.S. Federal Trade Commission (FTC) recognized privacy by design as one of its three recommended practices for protecting online privacy in its report entitled *Protecting Consumer Privacy in an*

Era of Rapid Change, and the FTC included privacy by design as one of the key pillars in its Final Commissioner Report on Protecting Consumer Privacy. In Australia, the Commissioner for Privacy and Data Protection for the State of Victoria (CPDP) has formally adopted privacy by design as a core policy to underpin information privacy management in the Victorian public sector. The UK Information Commissioner's Office website highlights privacy by design and data protection by design and default. In October 2014, the Mauritius Declaration on the Internet of Things was made at the 36th International Conference of Data Protection and Privacy Commissioners and included privacy by design and default. The Privacy Commissioner for Personal Data, Hong Kong held an educational conference on the importance of privacy by design.

In the private sector, Sidewalk Toronto commits to privacy by design principles; Brendon Lynch, Chief Privacy Officer at Microsoft, wrote an article called Privacy by Design at Microsoft; whilst Deloitte relates certifiably trustworthy to privacy by design.

Criticism and recommendations

The privacy by design framework attracted academic debate, particularly following the 2010 International Data Commissioners resolution that provided criticism of privacy by design with suggestions by legal and engineering experts to better understand how to apply the framework into various contexts.

Privacy by design has been critiqued as "vague" and leaving "many open questions about their application when engineering systems." Suggestions have been made to instead start with and focus on minimizing data, which can be done through security engineering.

In 2007, researchers at K.U. Leuven published Engineering Privacy by Design noting that "The design and implementation of privacy requirements in systems is a difficult problem and requires translation of complex social, legal and ethical concerns into systems requirements". The principles of privacy by design "remain vague and leave many open questions about their

application when engineering systems". The authors argue that "starting from data minimization is a necessary and foundational first step to engineer systems in line with the principles of privacy by design". The objective of their paper is to provide an "initial inquiry into the practice of privacy by design from an engineering perspective in order to contribute to the closing of the gap between policymakers' and engineers' understanding of privacy by design."

Extended peer consultations performed 10 years later in an EU project however confirmed persistent difficulties in translating legal principles into engineering requirements. This is partly a more structural problem due to the fact that legal principles are abstract, open-ended with different possible interpretations and exceptions, whereas engineering practices require unambiguous meanings and formal definitions of design concepts.

In 2011, the Danish National It and Telecom Agency published a discussion paper in which they argued that privacy by design is a key goal for creating digital security models, by extending the concept to "Security by Design". The objective is to balance anonymity and surveillance by eliminating identification as much as possible.

Another criticism is that current definitions of privacy by design do not address the methodological aspect of systems engineering, such as using decent system engineering methods, e.g. those which cover the complete system and data life cycle. This problem is further exacerbated in the move to networked digital infrastructures initiatives such as the smart city or the Internet of Things. Whereas privacy by design has mainly been focused on the responsibilities of singular organisations for a certain technology, these initiatives often require the interoperability of many different technologies operated by different organisations. This requires a shift from organisational to infrastructural design.

The concept of privacy by design also does not focus on the role of the actual data holder but on that of the system designer. This role is not known in privacy law, so the concept of privacy by design is not based on law. This, in turn, undermines the trust by data subjects, data

holders and policy-makers. Questions have been raised from science and technology studies of whether privacy by design will change the meaning and practice of rights through implementation in technologies, organizations, standards and infrastructures. From a civil society perspective, some have even raised the possibility that a bad use of these design-based approaches can even lead to the danger of bluewashing. This refers to the minimal instrumental use by organizations of privacy design without adequate checks, in order to portray themselves as more privacy-friendly than is factually justified.

It has also been pointed out that privacy by design is similar to voluntary compliance schemes in industries impacting the environment, and thus lacks the teeth necessary to be effective, and may differ per company. In addition, the evolutionary approach currently taken to the development of the concept will come at the cost of privacy infringements because evolution implies also letting unfit phenotypes (privacy-invading products) live until they are proven unfit. Some critics have pointed out that certain business models are built around customer surveillance and data manipulation and therefore voluntary compliance is unlikely.

In 2013, Rubinstein and Good used Google and Facebook privacy incidents to conduct a counterfactual analysis in order to identify lessons learned of value for regulators when recommending privacy by design. The first was that "more detailed principles and specific examples" would be more helpful to companies. The second is that "usability is just as important as engineering principles and practices". The third is that there needs to be more work on "refining and elaborating on design principles—both in privacy engineering and usability design". including efforts to define international privacy standards. The final lesson learned is that "regulators must do more than merely recommend the adoption and implementation of privacy by design".

The advent of GDPR with its maximum fine of 4% of global turnover now provides a balance between business benefit and turnover and addresses the voluntary compliance criticism and requirement from Rubinstein and Good that "regulators must do more than merely

recommend the adoption and implementation of privacy by design". Rubinstein and Good also highlighted that privacy by design could result in applications that exemplified Privacy by Design and their work was well received.

The May 2018 European Data Protection Supervisor Giovanni Buttarelli's paper Preliminary Opinion on Privacy by Design states, "While privacy by design has made significant progress in legal, technological and conceptual development, it is still far from unfolding its full potential for the protection of the fundamental rights of individuals. The following sections of this opinion provide an overview of relevant developments and recommend further efforts".

The executive summary makes the following recommendations to EU institutions:

- To ensure strong privacy protection, including privacy by design, in the ePrivacy Regulation,
- To support privacy in all legal frameworks which influence the design of technology, increasing incentives and substantiating obligations, including appropriate liability rules,
- To foster the roll-out and adoption of privacy by design approaches and PETs in the EU and at the member states' level through appropriate implementing measures and policy initiatives,
- To ensure competence and resources for research and analysis on privacy engineering and privacy-enhancing technologies at EU level, by ENISA or other entities,
- To support the development of new practices and business models through the research and technology development instruments of the EU,
- To support EU and national public administrations to integrate appropriate privacy by design requirements in public procurement,
- To support an inventory and observatory of the "state of the art" of privacy engineering and PETs and their advancement.

The EDPS will:

Continue to promote privacy by design, where appropriate in cooperation with other data

protection authorities in the European Data Protection Board (EDPB),

Support coordinated and effective enforcement of Article 25 of the GDPR and related provisions,

Provide guidance to controllers on the appropriate implementation of the principle laid down in the legal base, and

Together with data protection authorities of Austria, Ireland and Schleswig-Holstein, award privacy friendly apps in the mobile health domain.

Implementing privacy by design

The European Data Protection Supervisor Giovanni Buttarelli set out the requirement to implement privacy by design in his article. The European Union Agency for Network and Information Security (ENISA) provided a detailed report Privacy and Data Protection by Design – From Policy to Engineering on implementation. The Summer School on real-world crypto and privacy provided a tutorial on "Engineering Privacy by Design". The OWASP Top 10 Privacy Risks Project for web applications that gives hints on how to implement privacy by design in practice. The OASIS Privacy by Design Documentation for Software Engineers (PbD-SE) offers a privacy extension/complement to OMG's Unified Modeling Language (UML) and serves as a complement to OASIS' eXtensible Access Control Mark-up Language (XACML) and Privacy Management Reference Model (PMRM). Privacy by Design guidelines are developed to operationalise some of the high-level privacy-preserving ideas into more granular actionable advice., such as recommendations on how to implement privacy by design into existing (data) systems. However, still the applications of privacy by design guidelines by software developers remains a challenge.

See also

Computer security

Consumer privacy

General Data Protection Regulation

FTC fair information practice

Internet privacy

Mesh networking

Dark web

End-to-end encryption

Personal data service

Privacy engineering

Privacy-enhancing technologies

Surveillance capitalism

User interface design

== References ==